



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temas Específicos para la preparación de la Oposición al Cuerpo
Superior de Sistemas y Tecnologías de la Información de la
Administración del Estado.

TEMAS ESPECÍFICOS IV: Redes, comunicaciones e Internet

**Tema 128. La gestión de la continuidad del negocio. Planes de
Continuidad y Contingencia del Negocio**

AUTOR: Javier Hernández Castellano

Actualización 2019

ÍNDICE

1	LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO: ISO 22301:2012	3
1.1	INTRODUCCIÓN.....	3
1.2	CONTEXTO DE LA ORGANIZACIÓN (PLANIFICAR)	5
1.3	LIDERAZGO (PLANIFICAR).....	5
1.4	LOS OBJETIVOS DEL SGCN (PLANIFICAR)	7
1.5	COMPETENCIAS, COMUNICACIÓN Y DOCUMENTACIÓN: APOYO (PLANIFICAR) ...	7
1.6	OPERACIÓN (HACER)	8
1.7	EVALUACIÓN DEL RENDIMIENTO (VERIFICAR).....	12
1.8	MEJORA (ACTUAR)	13
1.9	CONCLUSIÓN	13
2	PLANES DE CONTINUIDAD Y CONTINGENCIA DE NEGOCIO	15
2.1	INTRODUCCIÓN.....	15
2.2	TIPOS DE PLANES DE CONTINUIDAD.....	15
2.3	FASE 0: DETERMINACIÓN DEL ALCANCE.....	16
2.4	FASE 1: ANÁLISIS DE LA ORGANIZACIÓN	16
2.5	FASE 2: DETERMINACIÓN DE LA ESTRATEGIA DE CONTINUIDAD	18
2.6	FASE 3: RESPUESTA A LA CONTINGENCIA	18
2.7	FASE 4: PRUEBA, MANTENIMIENTO Y REVISIÓN	19
2.8	FASES 5: CONCIENCIACIÓN.....	20
2.9	CONCLUSIÓN	21
3	GLOSARIO	23
4	PREGUNTAS DE TEST	25
4.1	SOLUCIONES A LAS PREGUNTAS DE TEST	29
5	BIBLIOGRAFÍA BÁSICA.....	30
6	BIBLIOGRAFÍA PARA AMPLIAR	31

1 La gestión de la continuidad del negocio: ISO 22301:2012

1.1 Introducción

La gestión de la continuidad de negocio está normalizada por la Norma Internacional ISO 22301:2012 adoptada por la Norma Europea EN ISO 22301:2014 y la Norma Nacional UNE-EN ISO 22301:2015 (enero de 2015).

A día de hoy se está desarrollando la ISO/DIS 22301:2019 (Security and resilience – Business continuity management systems – Requirements)

Esta norma especifica los requisitos de establecimiento y gestión de un Sistema de Gestión de la Continuidad de Negocio eficaz.

Todo Sistemas de Gestión de la Continuidad del Negocio (SGCN) debe basarse en:

- El análisis de las necesidades de la organización y del beneficio de la política y objetivos de la continuidad del negocio
- La implantación y ejecución de controles y medidas para gestionar la capacidad de la organización frente a incidentes que amenacen la continuidad del servicio
- La supervisión y revisión del rendimiento del SGCN
- La mejora continua realizando mediciones objetivas

Todo SGCN posee estos componentes principales:

- 1 Una política
- 2 Personas con responsabilidades bien delimitadas
- 3 Procesos de gestión de:
 - 3.1 La política
 - 3.2 La planificación
 - 3.3 La implantación y la operación
 - 3.4 La evaluación del rendimiento
 - 3.5 La revisión por la dirección
 - 3.6 La mejora
- 4 Pruebas auditables documentadas
- 5 Todos los procesos de SGCN importantes de la organización

Los Sistemas de Gestión de continuidad de Negocio se basan en **el modelo Planificar-Hacer-Verificar-Actuar (PHVA)**.

Así la gestión de continuidad de negocio aplica el modelo “Planificar-Hacer-Verificar-Actuar” (PDCA – Plan-Do-Check-Act) para planificar, establecer, implantar, operar, supervisar, revisar, mantener y mejorar de forma continua la eficacia del SGCN de una organización:

- Planificar (establecer): definir la política de continuidad de negocio, los objetivos y metas, controles, procesos y procedimientos para mejorar la continuidad de negocio y obtener resultados en línea con las políticas y objetivos de la organización.

- Hacer (implantar y operar): implantar y operar la política, los controles, los procesos y procedimientos de la continuidad de negocio.
- Verificar (supervisar y revisar): supervisar y revisar el rendimiento en base a objetivos y política de continuidad de negocio. Además informar de resultados a la dirección y definir medidas para su corrección y mejora.
- Actuar (mantener y mejorar): mantener y mejorar el SGCN aplicando medidas correctoras, en base a los resultados de la revisión por la dirección, y evaluando de nuevo el alcance del SGCN, política y objetivos de continuidad de negocio.

La siguiente figura muestra el modelo aplicado a procesos de SGCN:

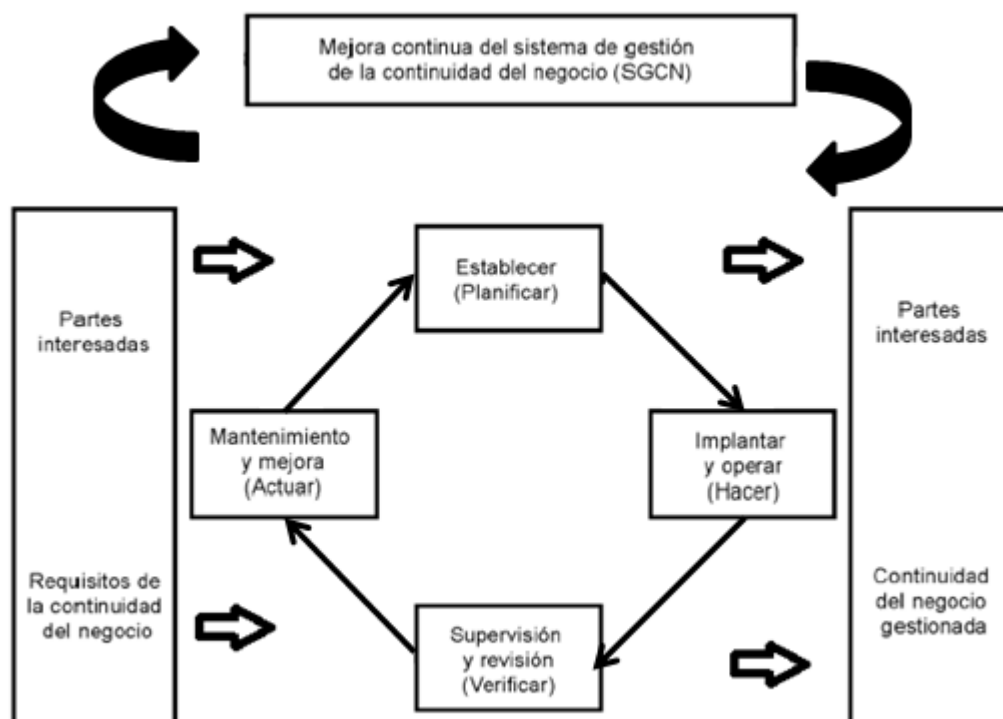


Figura 1 Modelo PDCA aplicado a procesos de SGCN

Así la ISO 22301:2012, se organiza con el PDCA, como lo hará esta parte del tema. Por orden temporal y de forma cíclica y continua todo Sistema de Continuidad de Negocio debe planificar estableciendo el **contexto de la organización** con su operativa, partes interesadas y alcance; el **liderazgo** con el compromiso de la dirección, la política del SGCN y los responsables del SGCN, los **objetivos** del SGCN y el **apoyo** al SGCN con las competencias y comunicaciones bien definidas y documentadas. Además el SGCN debe operar, la **operación** es definir la estrategia de continuidad de negocio en base al análisis de impacto y de riesgos, con sus planes, procedimientos, y equipos de continuidad de negocio. También debe verificar con la **evaluación del rendimiento** a través de procedimientos de supervisión, auditorías internas y revisión de la dirección. Por último se debe actuar, con la **mejora** continua del SGCN.

Por último en la conclusión se resumirá el epígrafe para su mejor entendimiento.

1.2 Contexto de la organización (Planificar)

En esta parte de la planificación se trata de establecer el contexto del SGCN, con sus necesidades, requisitos y alcance.

En cuanto a la **operativa de la organización** se debe identificar y documentar:

- Actividades, funciones, servicios, productos, asociaciones, flujos de trabajo, relaciones con stakeholders (partes interesadas), así como su impacto ante un incidente
- Las relaciones entre la política de continuidad de negocio y los objetivos de la organización, así como otras políticas, y la estrategia global de gestión de riesgos
- El nivel de riesgo de organización

Por tanto todo contexto debe:

- Definir sus objetivos de forma clara, así como los relativos a la continuidad de negocio
- Establecer factores y fuentes internas y externas que provocan riesgos
- Establecer la probabilidad e impacto de los riesgos
- Definir la finalidad del SGCN

Al definir el SGCN, la organización debe determinar las **Partes interesadas (Stakeholders)** así como sus necesidades y expectativas respecto de la organización:

- Stakeholders relacionadas con SGCN y sus requisitos (necesidades y expectativas implícitas u obligatorias)
- Procedimientos que permitan identificar, acceder, evaluar los **requisitos legales y reglamentarios** de la organización relativos a la continuidad de sus operaciones, productos y servicios así como los derechos de los stakeholders relacionados. Esta información debe estar documentada y actualizada así como transmitida a empleados e interesados que corresponda

Además todo contexto debe delimitar el **Alcance del SGCN** o determinar el campo de aplicación del SGCN:

- Definir las partes de la organización a incluir en el SGCN
- Definir **requisitos del SGCN** teniendo en cuenta la misión, metas, obligaciones (internas y externas) y las responsabilidades legales y reglamentarias
- Identificar los productos, servicios y actividades relacionados con SGCN
- Las necesidades de los stakeholders
- Tener en cuenta el tamaño, naturaleza y complejidad de la organización

1.3 Liderazgo (Planificar)

En esta parte de la planificación se describen los requisitos de la función de la alta dirección en el SGCN y cómo a través de la política se comunica al resto de la organización las expectativas del sistema.

La alta dirección debe estar comprometida y liderar el SGCN, el **Compromiso de la dirección** se debe plasmar:

- Posibilitando las políticas y objetivos de SCGN alineados con la dirección estratégica de la organización
- Fomentando la integración de los requisitos del SGCN en los procesos de negocio de la organización
- Dotando de recursos al SGCN
- Consiguiendo que la continuidad de negocio sea permeable en la organización: difundir la importancia de la gestión de la continuidad de negocio y fomentar que los mandos intermedios demuestren liderazgo y compromiso en sus distintas áreas.
- Realizando el seguimiento de los resultados del SGCN
- Dirigiendo y apoyando a las personas encargadas del SGCN
- Fomentando la mejora continua

La alta dirección debe definir las siguientes herramientas y procesos para cubrir lo anterior y facilitar el establecimiento, operación, supervisión, revisión, mantenimiento y mejora del SGCN:

- La Política de Continuidad de Negocio
- Los Objetivos y planes del SGCN
- Definir y normalizar puestos con funciones, responsabilidades y competencia de la gestión de la continuidad de negocio en la organización. Asegurando la formación continua de las personas que ocupen los puestos así como su carrera profesional orientada a la continuidad de negocio
- Determinar Responsables del SGCN con autoridad y funciones para implantar y mantener el SGCN. Los responsables deben velar por que el SGCN sea acorde a la normativa e informar sobre su rendimiento a la alta dirección

La política del SGCN se debe caracterizar por:

- Estar en línea con los objetivos de la organización
- Definir la estructura que establezca los objetivos de continuidad de negocio
- Incluir la obligatoriedad de los requisitos de SGCN
- Incluir la obligatoriedad de la mejora continua

Además la política debe:

- Estar documentada y disponible
- Difundirse dentro de la organización
- Estar disponible para los stakeholders o partes interesadas, según corresponda
- Revisarse periódica y sistemáticamente garantizando su idoneidad para la organización

Además la alta dirección debe garantizar la asignación y difusión de la **autoridad y responsabilidades de los responsables del SGCN**, para garantizar que el SGCN es conforme a la Norma Internacional ISO 22301:2012 y de que es informada del rendimiento del SGCN por dichos responsables. Para ello la alta dirección lo garantiza:

- Definiendo criterios de aceptación y niveles aceptables de riesgos
- Participando en las pruebas del SGCN
- Posibilitando auditorías internas de SGCN
- Revisando la dirección del SGCN
- Promoviendo y difundiendo la mejora continua

1.4 Los objetivos del SGCN (Planificar)

La alta dirección debe garantizar que los objetivos del SGCN se establecen y se comunican dentro de la organización y asegurar que los objetivos:

- Están en línea con la política
- Valoran el nivel mínimo de servicios y productos aceptables para que la organización consiga sus objetivos
- Son medibles
- Tienen en cuenta los requisitos de la política
- Son supervisados y actualizados

Cada objetivo debe tener:

- Responsable
- Acciones
- Recursos necesarios
- Planificación
- Evaluación de resultados con sus indicadores

1.5 Competencias, comunicación y documentación: apoyo (Planificar)

En esta parte de la planificación se describen las operaciones para definir competencias, comunicaciones con stakeholders o partes interesadas y ciclo de vida de la documentación del SGCN.

En cuanto a **Competencias** la organización debe:

- Asignar y definir las competencias de su personal
- Posibilitar la formación inicial, formación continua y desarrollo de carrera profesional
- Evaluar la formación continua (análisis de resultados de esta)
- Almacenar la documentación que acredite las competencias del personal

Respecto a **Concienciación y comunicación** la organización debe conseguir que todo trabajador este concienciado sobre:

- La política de continuidad de negocio
- Los beneficios y eficacia del SGCN
- Las consecuencias de no cumplir los requisitos del SGCN
- Sus protocolos de actuación ante un incidente

Además la organización debe definir cómo serán las comunicaciones del SGCN y cuál será su procedimiento de comunicación. En cuanto al cómo se debe detallar:

- Temática de las comunicaciones
- Cuándo se comunicarán
- Cómo comunicarse (qué medios)

- A quién comunicar
- Quién comunicará

La organización debe contar con procedimientos de comunicación para:

- Comunicaciones internas y externas
- Recepción, almacenado y respuesta de comunicaciones con stakeholders
- Integración de un sistema de aviso de amenazas a la continuidad de negocio
- Disponibilidad de medios de comunicación ante incidentes y pruebas periódicas de estos
- Asegurar la interoperabilidad con otras organizaciones y usuarios

Por último es fundamental el ciclo de vida de la **Documentación** del SGCN, toda documentación asociada al SGCN debe tener:

- Identificación y descripción: metadatos que la cataloguen (título, fecha, autor, identificador ...)
- Un formato definido, soportes posibles y revisión y aprobación

Toda la documentación debe ser controlada para asegurar su:

- Disponibilidad y uso de forma independiente al tiempo y lugar
- Confidencialidad e integridad
- Trazabilidad de uso (evitar o conocer usos incorrectos)

Las actividades que la organización debe realizar para su control son:

- Distribución, acceso, recuperación y utilización
- Almacenaje y conservación (asegurando la legibilidad)
- Control de versiones o modificaciones
- Retención y disposición
- Recuperación y utilización
- No utilización de información obsoleta

1.6 Operación (Hacer)

En la fase de operación todo SGCN debe planificar, implantar y controlar procesos de continuidad de negocio. Para ello se debe realizar un análisis de impacto de negocio y un análisis de riesgos.

El análisis de impacto de negocio identifica las actividades críticas de la organización (que producen productos y servicios), evalúa el impacto de su no realización y define plazos de reanudación aceptables. El análisis de riesgos identifica los riesgos posibles sobre dichas actividades y su posibilidad de ocurrencia.

En base a estos análisis se define la Estrategia de continuidad de negocio con los procedimientos y equipos de continuidad de negocio y los planes de continuidad de negocio.

Así la organización debe planificar, implantar y controlar los procesos necesarios para cumplir los requisitos del SGCN:

- Estableciendo indicadores para los procesos
- Implantado un control de procesos en base a los indicadores
- Documentando el control de procesos para comprobar que los procesos se ejecutan según lo estipulado

Para ello es necesario realizar un **análisis de impacto de negocio y de riesgos** de la organización para establecer, implantar y mantener un procedimiento formal y documentado de análisis de riesgos y de impacto en el negocio que:

- Defina la probabilidad de los riesgos, su contexto y su impacto
- Esté adecuado a la normativa y otros requisitos de la organización
- Tenga análisis sistemático, prioridades de los tratamientos de riesgos y costes asociados
- Defina el resultado óptimo del análisis de riesgos (el nivel de riesgo a asumir por la organización)
- Defina el periodo de actualización del análisis de riesgos y confidencialidad de este

El **análisis de impacto sobre el negocio** es necesario para identificar las operaciones y servicios “críticos” para la entidad, los principales factores de los que depende su continuidad (tanto internos como externos), así como los niveles de protección adecuados ante distintas posibles situaciones.

El análisis de impacto sobre el negocio debe contener:

- Actividades de la organización que producen productos y servicios
- Evaluación del impacto temporal de la no realización de cada actividad
- Definición de plazos de reanudación de actividades aceptables
- Identificación de dependencias y recursos de las actividades (cualquier parte interesada que participe en la actividad)

El **análisis de riesgos** debe:

- Identificar los riesgos de las actividades de la organización, procesos, sistemas, información, personas, bienes, socios externos u otros recursos cualesquiera de la organización
- Analizar los riesgos periódicamente
- Evaluar los riesgos relacionados con interrupciones que requieren tratamiento
- Identificar procedimientos a aplicador para cada riesgo conforme a los objetivos de continuidad de negocio y el nivel del riesgo

La **Estrategia de continuidad de negocio** o recuperación establece los objetivos y prioridades de recuperación en función de los resultados del análisis del impacto sobre el negocio. Debe incluir, entre otros aspectos, el “nivel objetivo de servicio” que una entidad desea ofrecer en el caso de que se presenten este tipo de problemas, así como el marco que le permita volver a la situación inicial.

La estrategia de continuidad de negocio se debe basar en los resultados del análisis de impacto en el negocio y el análisis de riesgos. La estrategia debe:

- Salvaguardar las actividades más importantes
- Estabilizar, continuar, reanudar y recuperar dichas actividades, su dependencias y su recursos
- Mitigar, gestionar y responder a los impactos

- Incluir los plazos de reanudación de actividades
- Incluir cómo evaluar a los proveedores externos

Para la implantación de la estrategia seleccionada, la organización debe definir los requisitos de los recursos de las actividades. Los recursos deben incluir al menos:

- Personas
- Informaciones y datos
- Edificios, entorno de trabajo y servicios asociados
- Instalaciones, equipos y consumibles
- Sistemas TIC
- Transportes
- Finanzas
- Socios y proveedores

La estrategia de continuidad de negocio debe incluir medidas proactivas ante los riesgos que requieran tratamiento que:

- Disminuyan la probabilidad de corte de servicio
- Disminuyan el periodo de interrupción
- Reduzcan el impacto de corte de servicio sobre los servicios y productos de la organización

Una vez definida la Estrategia de continuidad de negocio se debe definir los procedimientos y equipos de continuidad de negocio que formarán parte de los planes de continuidad de negocio.

Los **Procedimientos de continuidad de negocio** deben ser establecidos, implantados y mantenidos para gestionar los incidentes y continuar con las actividades. Deben estar basados en los objetivos de recuperación del análisis de impacto de negocio. Dichos procedimiento deben ser documentados para asegurar su éxito.

Los procedimientos deben:

- Tener un protocolo de comunicaciones internas y externas, con asignación de roles y responsabilidades
- Contener medidas específicas a realizar durante la interrupción que minimicen las consecuencias
- Ser flexibles con amenazas imprevistas o cambios de condiciones internas o externas
- Estar dirigidos a los sucesos que interrumpen operaciones

Además la organización debe gestionar procedimientos de **aviso y comunicación** para:

- Detectar incidentes y supervisar incidentes
- Comunicar internamente y externamente de forma adecuada
- Garantizar los sistemas de comunicación durante los incidentes así como su interoperabilidad
- Registrar la información del ciclo de vida del incidente
- Ser probados periódicamente para garantizar su funcionamiento en caso de incidente

La organización debe someter a **pruebas y ensayos** todos sus procedimientos de continuidad de negocio para garantizar que se cumplen los objetivos de continuidad de negocio definidos en la estrategia. Las pruebas y ensayos deben:

- Ser coherentes con el campo de aplicación y objetivos del SGCN
- Definir escenarios con metas y objetivos bien definidos
- Ser ejecutadas de forma periódica o cuando haya cambios relevantes en la organización o su entorno
- Minimizar el riesgo de interrupción
- Cada prueba debe tener un informe de resultados, recomendaciones y acciones a tomar.
- Ser revisadas dentro del contexto de mejora continua

La organización debe de gestionar los **Equipos de continuidad de negocio** para responder a incidentes, utilizando personal con autoridad, responsabilidad y competencia.

Los equipos de continuidad de negocio deben:

- Evaluar la naturaleza de incidentes y sus impactos potenciales
- Definir umbrales de impacto que justifiquen la respuesta y activación de los procedimientos de continuidad de negocio
- Activar la respuestas de continuidad de negocio adecuadas
- Planificar las acciones que debe ser tomadas estableciendo prioridades
- Monitorizar los efectos del incidentes y de las respuestas a este
- Comunicar a las partes interesadas y autoridades en caso necesario

Los **Planes de continuidad de negocio** son guías detalladas para la implantación de la estrategia de recuperación. Establecen y asignan las funciones, responsabilidades y delegación de poderes en caso de que un suceso de gravedad extrema afecte al personal clave de una entidad. Definen también los mecanismos de activación de los planes de continuidad.

La organización debe establecer planes de continuidad de negocio que deben contener:

- Funciones y responsabilidades de los equipos con autoridad ante incidentes
- Un proceso que active la respuesta ante incidentes
- Cómo gestionar incidentes teniendo en cuenta el bienestar de personas, estrategia de la organización y actividades prioritarias de esta
- Cómo comunicar los incidentes a empleados, familiares, partes interesadas o stakeholders, servicios de emergencia....
- Cómo continuar el servicio dentro de los periodos establecidos
- Cómo se dará respuesta del incidente a los medios de comunicación en caso necesario: qué estrategia de comunicaciones a seguir, qué medio utilizar, directrices o modelo de reacción y el portavoz apropiado
- El proceso de finalización una vez el incidente sea mitigado

A su vez cada plan debe tener definido:

- Finalidad y campo de aplicación
- Objetivos
- Criterios y procedimientos de activación
- **Procedimientos de continuidad de negocio** que aplican al plan
- Funciones, responsabilidades y autoridades: **equipos de continuidad de negocio**
- Requisitos y procedimientos de comunicación
- Interdependencias y relaciones internas y externas

- Requisitos de los recursos
- Procesos de flujo de información y comunicación

1.7 Evaluación del rendimiento (Verificar)

La organización, para evaluar el rendimiento y eficacia de su SGCN debe definir:

- Qué supervisar y medir
- Cómo supervisar, medir, analizar y evaluar
- Cuándo supervisar y medir
- Cuándo evaluar y analizar resultados de las supervisión y mediciones

Esta evaluación del rendimiento permite prevenir posibles interrupciones. Todas las evaluaciones deben ser conservadas como evidencias de los resultados.

Los **procedimientos de supervisión** deben:

- Definir indicadores de rendimiento de la organización
- Supervisar el cumplimiento de la política de continuidad de negocio, objetivos y metas del SGCN
- Supervisar los procedimientos de continuidad de negocio de las actividades prioritarias
- Supervisar el cumplimiento de la normativa aplicable
- Supervisar evidencias de interrupciones de servicio surgidas y revisar su evolución
- Registrar y documentar los resultados de evaluaciones

Así la organización debe de evaluar sus procedimientos de continuidad de negocio:

- de forma periódica o cuando haya cambios significativos,
- para verificar que siguen siendo adecuados y eficaces,
- conformes a la normativa aplicable y mejores prácticas así como a la política y objetivos de continuidad de negocio

Cuando se produce un incidente que produce la activación de un procedimiento de continuidad de negocio, siempre se debe hacer una revisión posterior al incidente y documentar los resultados.

Además de los procedimientos de supervisión se debe realizar auditorías internas y revisiones de la dirección.

Para validar que el SGCN es conforme a los requisitos de este y a la normativa aplicable (ISO 22301:2012) y está implantado y mantenido de forma eficaz se deben realizar **auditorías internas**, así la organización debe:

- Gestionar programas de auditoria con frecuencia, métodos, responsabilidades, planificación de requisitos y realización de informes
- Definir los criterios y alcance de las auditorias
- Seleccionar auditores para realizar auditorías objetivas e imparciales
- Posibilitar que la dirección sea informada de los resultados de las auditorias
- Conservar los resultados de las auditorias

Los resultados de las auditorías y las mejoras propuestas deben ser ejecutados.

La alta dirección debe revisar el SGCN de forma periódica. Cada **revisión de la dirección** debe tener en cuenta:

- El estado de las acciones a llevar a cabo decididas en revisiones anteriores
- Los cambios internos y externos importantes para el SGCN, su política y objetivos
- La información del rendimiento del SGCN: no conformidades y acciones correctoras, resultados de la evaluación de la supervisión y medición y resultados de auditorías
- Las oportunidades de mejora continua
- Los riesgos no cubiertos en el análisis de riesgos anterior
- Las buenas prácticas y directrices que aparecen

Los resultados de estas revisiones deben decidir si modificar el SGCN para mejorar su eficacia:

- Cambiar su objetivos
- Actualización del análisis de riesgos, análisis de impacto en el negocio, planes de continuidad y procedimientos de continuidad de negocio
- Modificación de los procedimientos de continuidad de negocio y control de estos, así como la medición de dichos controles

1.8 Mejora (Actuar)

La organización, cuando se produce una no conformidad (o incidente) debe:

- Identificarla y reaccionar ante ella, controlándola y corrigiéndola y afrontando las consecuencias
- Evaluar la necesidad de aplicar acciones para que no se repita, revisando el incidente, causas y si existen otros riesgos similares
- Aplicar todas la acciones necesarias y revisar su eficacia
- Realizar cambios en el SGCN si fuese necesario
- Conservar toda la información del incidente, naturaleza de este y acciones tomadas, así como sus resultados

Además la organización debe de revisar y mejorar de manera continua la idoneidad, adecuación y eficacia del SGCN, a través del liderazgo, planificación o evaluación del rendimiento de este.

1.9 Conclusión

La Gestión de la Continuidad de Negocio, viene normalizada por la Norma Internacional ISO 22301:2012 adoptada por la Norma Europea EN ISO 22301:2014 y la Norma Nacional UNE-EN ISO 22301:2015 (enero de 2015). Adía de hoy se está desarrollando la ISO/DIS 22301:2019.

Esta norma especifica los requisitos de establecimiento y gestión de un Sistema de Gestión de la Continuidad de Negocio eficaz.

Toda organización que tenga o esté en proceso de implantar un Sistema de Gestión de Continuidad de Negocio debe saber que se enfrenta a un proceso de mejora continua, cíclico e infinito. Las

situaciones perfectas no existen, la coyuntura económica no ayuda, pero siempre es mejor hacer una Gestión de la Continuidad simple que no hacerla.

Toda organización que desee hacer continuidad de negocio, debe primero conocerse a sí misma lo mejor posible, y eso lo debe plasmar con el **contexto de la organización** con su operativa, partes interesadas y alcance. El alcance es importante, es mejor empezar por un alcance corto, un par de procedimientos críticos y cuando se haga todo el ciclo de la continuidad de negocio ir aumentando.

Es fundamental el **liderazgo**, sin apoyo de la dirección no hay continuidad de negocio, la dirección debe estar comprometida y su compromiso se debe plasmar en la **Política de Continuidad de Negocio** y en la elección y dotación de responsables de continuidad de negocio. Además deberá ser partícipe de las pruebas del sistema y formar parte de la evaluación de resultados. Por tanto la dirección define los **objetivos** del SGCN.

Para que todo funcione, existen unos procesos y tareas de **apoyo** al SGCN, que son dotar de responsabilidad al personal implicado en la continuidad de negocio y de conocimientos y herramientas con formación y formación continua, no sólo la inicial, de nuevo el apoyo de la dirección es vital. Además todo el personal debe conocer y aún más importante estar concienciado de la política de continuidad de negocio, requisitos y beneficios del SGCN. Por tanto es fundamental la comunicación y la documentación. El SGCN es independiente de las personas, es de la organización, debe estar totalmente documentado y accesible en cada caso por quien corresponda.

Una vez hemos planificado, con el contexto, liderazgo, objetivos y apoyo, llega la **operación**. Se debe definir la **estrategia de continuidad de negocio** en base del **análisis de impacto y de riesgos**. El análisis de impacto analiza los procesos y actividades de la organización críticos, evaluando su impacto en caso de incidente y definiendo los plazos de reanudación aceptables. Además analiza las dependencias de los procesos con otros o con partes interesadas. Por otro lado el de riesgos evalúa y establece probabilidades de impacto de los riesgos que afectan a los procesos y establece medidas para minimizar dichos riesgos.

La **Estrategia de Continuidad de Negocio** baja el nivel de abstracción de los objetivos y define objetivos y prioridades ante un incidente, definiendo los niveles de servicio aceptables en periodos de crisis, así como los tiempos de recuperación. Toda Estrategia se plasma en los **planes de continuidad de negocio** (otro nivel de abstracción menor) que a su vez se basan en **procedimientos de continuidad de negocio**.

Así una organización tiene unos objetivos del SGCN y una política del SGCN. Además tiene su estrategia de continuidad de negocio, que puede tener varios planes de continuidad de negocio y cada plan varios procedimientos de continuidad de negocio.

Por último es fundamental la **evaluación del rendimiento** a través de procedimientos de supervisión, auditorías internas y revisión de la dirección y la **mejora** continua del SGCN en base a las evaluaciones de rendimiento o incidentes ocurridos.

Todo organización, pública o privada, grande o pequeña, debe valorar en su presupuesto una partida para la continuidad de negocio. La cantidad de dicha partida puede ser ilimitada, pero toda cantidad de dinero invertida tiene beneficios que si bien son difíciles de cuantificar a corto plazo, dan una madurez y robustez a la organización inmediatas y que crecen exponencialmente.

2 Planes de continuidad y contingencia de negocio

2.1 Introducción

El anterior punto relata las directrices a seguir para todo Sistema de Gestión de Continuidad de Negocio en base a la Norma Internacional ISO 22301:2012 de gestión de la continuidad de negocio. Este punto baja en nivel de abstracción y detalla los tipos y fases de los planes de continuidad y contingencia de negocio.

Sintetizando al máximo los planes de continuidad de negocio nos ayudan a:

- Mantener el nivel de servicio en los límites definidos
- Establecer un periodo de recuperación mínimo
- Recuperar la situación inicial antes de cualquier incidente de seguridad
- Analizar los resultados y motivos de los incidentes
- Evitar que las actividades de las empresas se interrumpan

En cuanto al desarrollo del punto se empezará tipificando los planes, desde los planes de continuidad de negocio, planes de continuidad TIC o planes de recuperación de desastres.

Se seguirá con el detalle de las seis fases que son la determinación del alcance del plan, el análisis de la organización, la determinación de la estrategia de continuidad, la respuesta a la contingencia, la prueba mantenimiento o revisión del plan, así como la concienciación.

Por ultimo en la conclusión se resumirá el epígrafe para su mejor entendimiento.

2.2 Tipos de planes de continuidad

Aunque por norma general se enmarcan dentro del concepto de Plan de Continuidad de Negocio, podemos diferenciar tres tipos de planes en base a su ámbito o alcance. Las fases de todos ellos son las mismas.

PCN, Plan de Continuidad de Negocio: define la continuidad de negocio de una organización desde diversas perspectivas: infraestructura TIC, recursos humanos, mobiliario, sistemas de comunicación, logística, sistemas industriales, infraestructuras físicas, etc. Cada uno de estos tendrá un plan de continuidad más específico.

PCTIC, Plan de Continuidad TIC o Plan de Contingencia TIC: Plan de continuidad referido sólo al ámbito TIC.

PRD, Plan de Recuperación ante Desastres: Plan reactivo ante una posible catástrofe.

Todo PCN, tiene su PCTIC y su PRD. Todo PCTIC tiene su PRD.

Todos los planes de continuidad tienen las siguientes fases:

- Fase 0: Determinación del alcance
- Fase 1: Análisis de la organización
- Fase 2: Determinación de la Estrategia de Continuidad

- Fase 3: Respuesta a la contingencia
- Fase 4: Prueba, mantenimiento y revisión
- Fase 5: Concienciación

2.3 Fase 0: Determinación del alcance

Para determinar el alcance y asignar los recursos y tiempos óptimos para la mejora continua, se debe empezar por los departamentos o áreas más críticas e importantes de la organización. Siempre que se cuente con el compromiso de la dirección de ampliar la continuidad a toda la organización.

La fase se caracteriza por:

- Ser la de menor duración y número de recursos
- Determinar la magnitud y coste del proyecto, así como su viabilidad futura
- Definir qué elementos de la organización van a ser el foco de la mejora continua
- Afectar al personal, activos de información, sistemas informáticos, servicios y procesos de la organización (lo normal es que por ejemplo un PRD esté enfocado más en los activos y un PCTIC en los procesos).
- Tener como alcance los sistemas o procesos de mayor criticidad, cuya pérdida generaría más impacto en nuestra organización. Ejemplo: en una reprografía sus elementos más críticos son sus impresoras o en un colegio sus profesores.
- Requerir de la colaboración de todos los departamentos implicados

El enfoque del plan puede ser por activo o por proceso. El **Enfoque por activo** mejora la continuidad de un conjunto de activos, y a partir de estos obtiene los procesos que los utilizan. Es propio de un PRD o cuando el plan es elaborado por un área técnica.

El **Enfoque por proceso** mejora los procesos, con independencia de los activos que le den soporte. Es propio de un PCN y por tanto el explicado para el resto de fases.

2.4 Fase 1: Análisis de la organización

En esta fase se deben identificar los procesos críticos de negocio, sus activos, así como necesidades temporales y recursos o lo que es lo mismo obtener, elaborar y comprender las circunstancias, tecnologías, procesos y recursos de nuestra organización.

Se debe:

- **Mantener reuniones** con los usuarios finales del proceso de nuestro alcance para obtener dependencias de proveedores, personal implicado, aplicaciones que se utilicen y datos sobre necesidades temporales de cada aplicación.
- Recopilar toda la información sobre las aplicaciones del proceso (detalles de funcionamiento, instalación, proveedor, mantenimiento, copias de seguridad, acuerdos de nivel de servicio...)

Y con ello elaborar el Análisis de impacto sobre Negocio y el Análisis de riesgos.

El **Análisis de impacto sobre Negocio o BIA (Business Impact Analysis)** debe contener los requisitos temporales y de recursos de los procesos dentro del alcance:

- **RTO o Tiempo de recuperación** es el tiempo que un proceso estará detenido antes de ser restaurado. Tiene algo de subjetivo.
- **RRHH y tecnológicos del proceso:** personal crítico sin reemplazo (por corta plantilla o Know-how) y las aplicaciones, sistemas, equipamiento y elementos auxiliares necesarios para que un proceso funcione en contingencia.
- **Tiempo máximo tolerable de caída o MTD (Maximun Tolerable Downtime):** tiempo aceptable sin consecuencias desastrosas para la organización. El MTD está relacionado con el negocio y es subjetivo y el RTO es determinado por el personal técnico. El RTO debe ser inferior al MTD. Ejemplo: el procesos de nóminas tiene un RTO de 48 horas y su MTD es de 5 días. Si el proceso de nóminas se cae, tardaremos 48 horas en restaurarla y si es más de 5 días será desastroso para la organización
- **Niveles mínimos de recuperación de servicio o ROL (Revised Operating Level):** nivel mínimo de recuperación de una activad aunque el nivel de servicio sea de mínimo y no óptimo. Se establece en valores absolutos o porcentuales. Ejemplo: en un CAU atender el 70% de incidencias diarias.
- **Dependencias de otros procesos internos o proveedores externos.** En función de la criticidad de las actividades en las que el proveedor esté implicado, podemos solicitar a éste que indique si dispone de un Plan de Recuperación ante Desastres y qué intervalos temporales maneja. Así se verifica que una situación de desastre en un proveedor crítico no traslada dicha contingencia a nuestra empresa.
- **Grado de dependencia de la actualidad de los datos o RPO (Recovery Point Objective):** determina el impacto que tiene sobre la actividad la pérdida de datos. Este valor es crítico a la hora de determinar las políticas de copias de la organización. Pueden existir procesos con un RTO bajo y un RPO alto por poder utilizar datos antiguos.

Así sabemos qué procesos recuperar antes en base a su MTD. Qué aplicaciones recuperar antes en función de los procesos en los que intervengan y las políticas de copias de seguridad a realizar.

Dada la subjetividad del cálculo de algunos valores, se deben de contrastar con datos objetivos como incidencias pasadas, bajas de personal, etc... Estos valores determinan las medidas a tomar y el coste de estas. Por tanto se debe afinar en su cálculo.

Por otro lado con el **Análisis de riesgos** y a partir de las reuniones iniciales se deben estudiar amenazas de los procesos críticos, sus probabilidades, impactos y sus activos.

Procesos críticos podrían ser los de un MTD inferior a 24 horas. Las fases de todo análisis de riegos son:

- **Determinar las amenazas** de la organización que provocan una indisponibilidad de los procesos: robo de datos, inundación, corte eléctrico...
- **Definición de probabilidad e impacto** de las amenazas: se suelen usar escalas de 1 a 5 o de "Muy baja" a "Muy alta". Hay que centrarse en riesgos con impacto alto y probabilidades no despreciables que dificultarían la continuidad del negocio.
- **Producto de la probabilidad por el impacto** de cada amenaza, para categorizar los riesgos.

El listado de riesgos de la organización es un listado donde cada registro será una amenaza, su valor de impacto y probabilidad.

Existen metodologías más complejas y más objetivas que tienen en cuenta activos, vulnerabilidades, etc...

También es útil asignar valores temporales al impacto de las amenazas para relacionarlo con el RTO y MTD.

Cada riesgo debería ser tratado de alguna de las siguientes formas:

- Ser transferido a un tercero

- Eliminado
- Asumido
- Mitigarlo con la implantación de medidas

Como respuesta a los riesgos se debe generar un plan de tratamiento de riesgos (para los que superen cierto umbral), cada medida debe tener:

- Descripción o conjunto de controles
- Riesgo o riesgos que mitiga
- Fecha de implantación límite
- Responsable de implantación
- Recursos necesarios para su implantación

2.5 Fase 2: Determinación de la Estrategia de Continuidad

Con la Fase 0 y 1 tenemos los procesos críticos, tiempo necesarios de recuperación, requisitos de pérdida de datos, sus recursos, tiempos de recuperación de recursos y los riesgos de nuestra organización.

Se debe determinar en caso de desastre, si es posible restaurar los activos de los procesos críticos de negocio en el tiempo necesario, es decir si con los recursos actuales y sus estrategias de recuperación se cubren los MTD (Tiempo máximo tolerable de caída) de cada proceso. En los casos que no se pueda, se deben establecer estrategias de recuperación. Ejemplo: el proceso de nóminas con un MTD de 24 horas utiliza el correo electrónico, la intranet y la aplicación de nóminas. El correo y la intranet tienen un RTO de 6 horas y la aplicación de nóminas 72 horas. Se deben implantar medidas para bajar el RTO de la aplicación de nóminas.

Los elementos que suelen ser afectados por contingencias son:

- Personal: evaluar opciones para mitigar la ausencia de personal crítico
- Locales: evaluarse situaciones sin lugar para trabajar
- Tecnología: para las distintas tecnologías de los activos que soportan el proceso se deben valorar alternativas de funcionamiento o medidas complementarias
- Información: se debe valorar la disponibilidad y confidencialidad de la información de procesos críticos
- Proveedores: revisar acuerdos de nivel de servicio con proveedores

Como resultado tendremos distintas estrategias de recuperación por proceso. Deben ser valoradas en bases a su coste y viabilidad de implantación, mantenimiento, recursos necesarios... para obtener un conjunto de estrategias a implantar para mejorar la continuidad de negocio.

2.6 Fase 3: Respuesta a la contingencia

Esta fase debe implantar la estrategia. El proceso comienza con la implantación de las estrategias para mejorar la continuidad de negocio, su clasificación y priorización de medidas en base al proceso y su criticidad.

En la implantación se aborda la fase de documentación de respuesta a la contingencia. Esta documentación se ejecuta en forma de árbol jerárquico, donde la raíz gestiona el momento inmediatamente posterior a la crisis, las ramas detallan las bases de recuperación de infraestructura y las hojas procedimientos técnicos detallados para la recuperación. Un ejemplo muy simplificado para la caída del correo electrónico de una organización sería:

1. Raíz: documento que contiene las comunicaciones a realizar y activa los procesos a realizar. Llamar a responsables de la organización, partes interesadas y personal implicado en la recuperación. Es el plan de crisis.
 - 1.1. 1^{er} nodo intermedio: apagado del sistema de correo electrónico
 - 1.1.1. 1^a hoja: Apagado de servicios de correo electrónico
 - 1.1.2. 2^a hoja: Apagado de servidor de correo electrónico
 - 1.2. 2^o nodo intermedio: Encendido del servicio de correo electrónico
 - 1.2.1. 3^a hoja: Encendido del servidor de correo electrónico
 - 1.2.2. 4^a hoja: Encendido de servicio de correo electrónico
 - 1.3. 3^{er} nodo intermedio: Puesta en marcha de correo electrónico
 - 1.3.1. 5^a hoja: Pruebas de correo electrónico
 - 1.3.2. 6^a hoja: Aviso a responsables de la organización y partes interesadas

Este proceso tiene los siguientes elementos: Plan de Crisis o de Incidentes, Planes Operativos de Recuperación de Entornos y Procedimientos técnicos de trabajo o de incidentes.

El **Plan de Crisis o de incidentes** es un documento que contiene todos los elementos cruciales para la gestión de los momentos iniciales de la crisis con el objetivo de no tomar decisiones improvisadas y equivocadas. Los elementos son:

- Condiciones de disparo: que sucesos o situación dispar la crisis. Se tienen en cuenta los MTDs de los procesos críticos
- Flujos de toma de decisiones
- Medios para la declaración de la crisis
- Personal encargado de activar el Plan de Crisis y gestionarlo
- Datos de contacto del personal implicado en la gestión de la crisis
- Niveles de priorización en la recuperación de la infraestructura de la organización
- Requisitos temporales de puesta en marcha
- Planes operativos existentes y personal responsable de su activación

Una vez pasado en momento inicial de la crisis se debe evaluar su alcance y ver qué **Planes Operativos de Recuperación de Entornos** se activan. Estos planes contienen uno o más entornos independientes y su información detallada. Ejemplos de entorno son el correo electrónico, el gestor documental, un ERP... Cada Plan Operativo de Recuperación de Entornos ordena qué Procedimientos Técnicos de Trabajo deben ser ejecutados.

Los **Procedimientos Técnicos de Trabajo** son la documentación que dice cómo gestionar y recuperar una aplicación, sistema, infraestructura o entorno. Estos documentos forman parte de la mejora continua y del día a día pero se vuelven cruciales en la gestión de crisis. Por ejemplo estos documentos contienen versionado de programas, listado de comandos, recuperación de copias de bases de datos, puesta en marcha de aplicativos...

2.7 Fase 4: Prueba, mantenimiento y revisión

Todo Plan de Continuidad debe mantenerse actualizado y comprobado regularmente. Por ejemplo en un PCTIC es considerado una buena práctica llevar a cabo pruebas de todos los entornos al menos una vez al año para cubrir todas las amenazas definidas como catastróficas. Cada prueba debe tener:

- Personal implicado en la prueba

- Usuarios para la prueba
- Personal externos implicado en la prueba
- Descripción detallada de la prueba a realizar
- Detalle del resultado esperado
- Hora y fecha de realización: siempre en horario de mínimo impacto, por si falla...

Tras la prueba debe documentarse el resultado con las incidencias surgidas. Toda incidencia debe ser analizada y corregida como proceso de mejora continua. Ejemplos de pruebas que deben realizarse en la mayoría de organizaciones son:

- Caída de suministro eléctrico: verificar sistema de alimentación interrumpida y grupo electrógeno
- Verificación de tiempos de recuperación de repositorios documentales y sus permisos asociados. Los permisos se deben mantener actualizados en los entornos de recuperación
- Recuperación de aplicaciones críticas del negocio y sus datos
- Acceso remoto desde fuera de la organización
- En entornos replicados o en clúster verificar la alta disponibilidad

El **Plan de mantenimiento** es un elemento en el que mantener actualizada toda la documentación ante cualquier cambio en la organización, para así asegurar que la documentación usada en una crisis está correctamente actualizada (infraestructura técnica, personal, proveedores externos, terceras partes... implicadas en una contingencia).

El Plan de mantenimiento a su vez define qué eventos disparan una revisión no planificada, como por ejemplo un cambio de proveedor, un cambio en un sistema, etc...

Un **Plan de Pruebas** contiene las pruebas de contingencia que se deben llevar a cabo en una organización. Estos planes ayudan a:

- Mantener la información actualizada
- En caso de contingencia la continuidad de la organización en los tiempo establecidos
- Mejorar la relación y rendimiento del personal implicado en una posible contingencia
- El conocimiento de los usuarios de la pruebas de continuidad
- Aumentar la confianza de los usuarios de la organización

2.8 Fases 5: Concienciación

Se debe plantear un proceso de concienciación que contemple la descripción de los elementos que se utilizan en la continuidad:

- Análisis de impacto sobre el negocio
- Plan de crisis
- Estrategias de recuperación
- Responsabilidades
- Plan de Pruebas
- Todo lo relacionado con el Plan de Contingencia que ayude a mejorar los periodos de recuperación

El público objetivo en este caso deberá ser tanto el personal técnico como el personal de negocio que tenga algún tipo de relación con los procesos críticos dentro del alcance.

2.9 Conclusión

Este segundo punto del tema profundiza sobre los planes de continuidad y contingencia del negocio. Debe quedar claro que existen distintos tipos de planes, el **PCN** o Plan de Continuidad de Negocio, el **PCTIC** o Plan de Continuidad TIC o el **PRD** o Plan de Recuperación de Desastres. Si bien todo PCN, tiene su PCTIC y su PRD y todo PCTIC tiene su PRD, todos comparten las mismas fases.

La **determinación del alcance** es fundamental para el éxito del plan, se debe empezar por los departamentos o áreas más críticas e importantes de la organización, siempre que se cuente con el compromiso de la dirección. El **enfoque del plan puede ser por proceso o por activo**. A más nivel de abstracción suele ser por proceso y a menos nivel por activo. Lo normal es que un PRD este enfocado más en los activos y un PCTIC o PCN en los procesos.

El **análisis de la organización** debe identificar los procesos críticos de negocio, sus activos, así como necesidades temporales y recursos o lo que es lo mismo obtener, elaborar y comprender las circunstancias, tecnologías, procesos y recursos de nuestra organización.

Para ello se realiza el **Análisis de impacto sobre Negocio** o BIA (Business Impact Analysis) que detalla para cada proceso o activo el **RTO** o Tiempo de recuperación, los **RRHH y tecnológicos** del proceso, el Tiempo máximo tolerable de caída o **MTD** (Maximun Tolerable Downtime), Niveles mínimos de recuperación de servicio o **ROL** (Revised Operating Level), las **dependencias** de otros procesos internos o proveedores externos y el grado de dependencia de la actualidad de los datos o **RPO** (Recovery Point Objective). Así sabemos qué procesos recuperar antes en base a su MTD. Qué aplicaciones recuperar antes en función de los procesos en los que intervengan y las políticas de copias de seguridad a realizar.

También se debe realizar el **análisis de riesgos** donde se estudian las amenazas de los procesos críticos, sus probabilidades, impactos y sus activos. El listado de riesgos de la organización es un listado donde cada registro será una amenaza, su valor de impacto y probabilidad.

Con la determinación del alcance y el análisis de la organización tenemos los procesos críticos, tiempos necesarios de recuperación, requisitos de pérdida de datos, sus recursos, tiempos de recuperación de recursos y los riesgos de nuestra organización. Con esta información se **determina la Estrategia de Continuidad**, que son un conjunto de estrategias de recuperación por proceso que deben ser elegidas en base a su coste, mantenimiento, recursos, etc... Se debe determinar en caso de desastre, si es posible restaurar los activos de los procesos críticos de negocio en el tiempo necesario. Por ejemplo: el proceso de nóminas con un MTD de 24 horas utiliza el correo electrónico, la intranet y la aplicación de nóminas. El correo y la intranet tienen un RTO de 6 horas y la aplicación de nóminas 72 horas. Se deben implantar medidas para bajar el RTO de la aplicación de nóminas.

Con la **respuesta a la contingencia** se implanta la estrategia. Se documenta la respuesta a la contingencia en forma de árbol jerárquico, la raíz gestiona el momento inmediatamente posterior a la crisis, es el **Plan de Crisis**; los elementos intermedios (ramas) ponen las bases de la recuperación, son los **Planes Operativos de Recuperación de Entornos** y las hojas contienen los procedimientos técnicos detallados de la recuperación, son los **Procedimientos técnicos de trabajo**.

Todo PCN debe mantenerse actualizado y comprobado regularmente. La fase de **Prueba, mantenimiento y revisión** consiste en la ejecución de pruebas que simulen una contingencia para verificar la implantación de la estrategia de continuidad y en caso necesario corregirla. Ejemplos de pruebas son la caída de suministro eléctrico o la verificación de la alta disponibilidad de entornos replicados. Toda organización debe tener su **plan de pruebas** y de mantenimiento. El **plan de mantenimiento** mantiene actualizada toda la documentación ante cualquier cambio en la

organización y define que eventos disparan una revisión no planificada, como por ejemplo un cambio de proveedor, un cambio en un sistema, etc...

Por último la fase de **concienciación** debe dar visibilidad a los análisis de impacto y riesgos, al plan de crisis, estrategias de recuperación, responsabilidades, planes de pruebas y todo relacionado con el Plan de Contingencia que ayude a mejorar los periodos de recuperación. El público objetivo es todo el personal, tanto técnico como de negocio, que tenga algún tipo de relación con los procesos críticos dentro del alcance del plan.

En definitiva aunque el alcance y detalle de un plan de continuidad y contingencia de negocio puede variar considerablemente de unas entidades a otras en función de sus características y perfil, todo plan debe ejecutar todas las fases y contener los elementos citados en cada una de ellas. Siempre será mejor delimitar un alcance corto y ejecutar todo el ciclo de mejora continua que un alcance mayor sin las últimas fases implantadas. **Aplicar todas las fases hacen que el plan “este vivo” y sea eficaz.**

3 GLOSARIO

- Actividad: proceso o conjunto de procesos realizados por una organización (o en su nombre) que producen o dan apoyo a uno o varios servicios o productos.
- Amenaza: suceso que provoca indisponibilidad de procesos.
- Análisis de impacto de negocio: proceso para analizar las actividades y el efecto que una interrupción del negocio puede tener sobre estas.
- Análisis de riesgos: proceso global de identificación y evaluación de riesgos.
- BIA (Business Impact Analysis): análisis de impacto de negocio, proceso para analizar las actividades y el efecto que una interrupción del negocio puede tener sobre estas.
- Continuidad de negocio: capacidad de la organización para continuar dando servicio a niveles predefinidos aceptables tras un incidente.
- Gestión de la continuidad de negocio: proceso de gestión holístico que identifica amenazas potenciales para la organización así como impactos en las operaciones del negocio que pueden producir y que proporciona un marco para aumentar la capacidad de resistencia de la organización para dar respuesta eficaz salvaguardando los intereses principales de las partes interesadas, la reputación, la marca y las actividades que crean valor.
- Impacto: consecuencias de una amenaza
- ISO/DIS 22301:2019: borrador de la Norma Internacional de Sistema de Gestión de Continuidad de Negocio.
- ISO: Organización Internacional de Normalización
- MTD (Maximun Tolerable Downtime): tiempo máximo tolerable de caída, tiempo aceptable sin consecuencias desastrosas para la organización. También conocido como plazo máximo tolerable de interrupción (PMTI) o tiempo máximo aceptable de interrupción (TMAI).
- Norma Europea EN ISO 22301:2014: versión oficial europea de la Norma Internacional ISO 22301:2012.
- Norma Internacional ISO 22301:2012: Norma Internacional de Sistema de Gestión de Continuidad de Negocio.
- Norma Nacional UNE-EN ISO 22301:2015: versión oficial, en español, de la Norma EN ISO 22301:2014.
- Objetivo: resultado a obtener.
- PCN: Plan de Continuidad de Negocio.
- PCTIC: Plan de Continuidad TIC o Plan de Contingencia TIC.
- PDCA: modelo Plan-Do-Check-Act.
- PHVA: modelo Planificar-Hacer-Verificar-Actuar.
- Plan de Continuidad de Negocio: procedimientos documentados que conducen a las organizaciones a responder, recuperar, reanudar y restaurar el nivel de operación predefinido después de una interrupción.
- Plan de Crisis o de incidente: documento que contiene todos los elementos cruciales para la gestión de los momentos iniciales de una crisis.
- Plan de mantenimiento: es un elemento en el que mantener actualizada toda la documentación ante cualquier cambio en la organización.
- Plan de Pruebas: contiene las pruebas de contingencia que se deben llevar a cabo en una organización.
- Planes Operativos de Recuperación de Entornos: documentación que contiene uno o más entornos independientes y su información detallada.
- Política: intenciones y orientaciones de una organización tal como son expresadas por la alta dirección.
- PRD: Plan de Recuperación ante Desastres.

- Procedimientos Técnicos de Trabajo: documentación que dice cómo gestionar y recuperar una aplicación, sistema, infraestructura o entorno.
- Requisito: necesidad o expectativa que se declara, generalmente implícita u obligatoria.
- Riesgo: efecto de la incertidumbre sobre la consecución de objetivos.
- ROL (Revised Operating Level): niveles mínimos de recuperación de servicio, nivel mínimo de recuperación de una actividad aunque el nivel de servicio sea de mínimo y no óptimo. También conocido como objetivo mínimo de continuidad de negocio (OMCN).
- RPO (Recovery Point Objective): grado de dependencia de la actualidad de los datos, determina el impacto que tiene sobre la actividad la pérdida de datos. Este valor es crítico a la hora de determinar las políticas de copias de la organización.
- RRHH: recursos humanos.
- RTO: Tiempo de recuperación, tiempo que un proceso estará detenido antes de ser restaurado.
- SGCN: Sistemas de Gestión de la Continuidad del Negocio, parte del sistema de gestión global de una organización que establece, implanta, opera, supervisa, revisa, mantiene y mejora la continuidad de negocio.
- Sistema TIC: sistema de Tecnologías de la Información y las Comunicaciones.
- Stakeholders o partes interesadas: persona u organización que puede afectar, ser afectada por, o percibir que ella misma puede verse afectada por una decisión o actividad.

4 PREGUNTAS DE TEST

- 1) La gestión de la continuidad de negocio está a día de hoy normalizada por la Norma Internacional:
 - a) ISO 22301:2012
 - b) ISO 22301:2018
 - c) ISO 27001:2013
 - d) EN ISO 22301:2014

- 2) La gestión de la continuidad de negocio está normalizada por la Norma Europea y Nacional:
 - a) Norma Europea EN ISO 22301:2015 y la Norma Nacional UNE-EN ISO 22301:2014
 - b) Norma Europea EN ISO 22301:2014 y la Norma Nacional UNE-EN ISO 22301:2016
 - c) Norma Europea EN ISO 22301:2014 y la Norma Nacional UNE-EN ISO 22301:2015
 - d) Norma Europea EN ISO 22301:2015 y la Norma Nacional UNE-EN ISO 22301:2016

- 3) Seleccione cuál de los siguientes no es un componente principal de un Sistema de Gestión de la Continuidad del Negocio (SGCN):
 - a) evaluación del rendimiento
 - b) política
 - c) revisión por la dirección
 - d) presupuestos anuales

- 4) La fase de planificación de un SGCN abarca:
 - a) El contexto, el liderazgo, los objetivos, las competencias, la comunicación y la documentación.
 - b) El contexto, el liderazgo, los objetivos, las competencias y la documentación
 - c) El contexto, el liderazgo, los riesgos externos, las competencias, la comunicación y documentación
 - d) Los sistemas de información, el liderazgo, los objetivos, las competencias, la comunicación y documentación

- 5) El alcance del SGCN debe tener en cuenta:
 - a) partes de la organización implicadas; requisitos; productos, servicios y actividades implicadas; necesidades de terceras partes; tamaño, naturaleza y complejidad de la organización.
 - b) partes de la organización implicadas; productos, servicios y actividades implicadas; necesidades de terceras partes; tamaño, naturaleza y complejidad de la organización.
 - c) partes de la organización implicadas; requisitos; productos y actividades implicadas; necesidades de terceras partes; tamaño, naturaleza y complejidad de la organización.
 - d) partes de la organización implicadas; requisitos; productos, servicios y actividades implicadas; necesidades de terceras partes; tamaño de la organización.

- 6) El compromiso de la dirección en un SGCN no se basa en
 - a) Posibilitar las políticas y objetivos de SGCN alineados con la dirección estratégica de la organización
 - b) Dotar de recursos al SGCN
 - c) Seguir de los resultados del SGCN

- d) Documentar los procesos de mejora continua
- 7) La política del SGCN no debe:
- a) Estar en línea con los objetivos de la organización y estar documentada y disponible sólo por parte de la organización
 - b) Ser difundida dentro de la organización
 - c) Incluir la obligatoriedad de la mejora continua
 - d) Ser revisada periódica y sistemáticamente garantizando su idoneidad para la organización
- 8) Un SGCN debe garantizar que todo trabajador esté concienciado de:
- a) La política de continuidad de negocio
 - b) La política de continuidad de negocio y beneficios y eficacia del SGCN
 - c) La política de continuidad de negocio, beneficios y eficacia del SGCN y las consecuencias de no cumplir los requisitos del SGCN
 - d) La política de continuidad de negocio, beneficios y eficacia del SGCN, sus protocolos de actuación ante un incidente y las consecuencias de no cumplir los requisitos del SGCN
- 9) El análisis de impacto sobre el negocio no debe contener:
- a) Actividades de la organización que producen productos y servicios
 - b) Evaluación del impacto temporal de la no realización de cada actividad
 - c) Identificación de dependencias y recursos de las actividades (cualquier parte interesada que participe en la actividad)
 - d) Identificar los riesgos de las actividades de la organización, procesos, sistemas, información, personas, bienes, socios externos u otros recursos cualesquiera de la organización.
- 10) El análisis de riesgos no debe:
- a) Analizar los riesgos periódicamente
 - b) Evaluar la probabilidad de los riesgos
 - c) Identificar procedimientos a aplicar para cada riesgo conforme a los objetivos de continuidad de negocio y probabilidad del riesgo
 - d) Definir plazos de reanudación de actividades aceptables
- 11) Los procedimientos de continuidad de negocio deben:
- a) Tener un protocolo de comunicación internas y externas, con asignación de roles y responsabilidades
 - b) Tener en cuentas la totalidad de amenazas previstas y condiciones internas o externas
 - c) Contener un esquema de medidas a realizar durante la interrupción
 - d) Estar dirigidos a todo tipo de sucesos
- 12) Los equipos de continuidad de negocio deben
- a) Evaluar la naturaleza de incidentes y sus impactos potenciales y definir umbrales de impacto que justifiquen la respuesta y activación de los procedimientos de continuidad de negocio
 - b) Planificar las acciones no priorizadas que deben ser tomadas y monitorizar los efectos de los incidentes y de las respuestas a este
 - c) Solicitar la activación de las respuestas de continuidad de negocio adecuadas
 - d) Evaluar la naturaleza de incidentes y sus impactos potenciales y solicitar la activación de las respuestas de continuidad de negocio adecuadas
- 13)Cuál de los siguientes no es un tipo de planes de continuidad de negocio:

- a) PCN, Plan de Continuidad de Negocio;
 - b) PCTIC, Plan de Continuidad TIC o Plan de Contingencia TIC
 - c) PRD, Plan de Recuperación ante Desastres
 - d) PAI, Plan de Auditorías Internas
- 14)Cuál de estas no es una fase de un plan de continuidad de negocio
- a) Determinación del alcance
 - b) Análisis de oportunidad de negocio
 - c) Prueba, mantenimiento y revisión
 - d) Análisis de la organización
- 15) Dentro del Análisis de impacto sobre Negocio o BIA cuál de las siguientes es falsa:
- a) RTO o Tiempo de recuperación es el tiempo que un proceso estará detenido antes de ser restaurado
 - b) Tiempo máximo tolerable de caída o MTD (Maximun Tolerable Downtime): tiempo aceptable sin consecuencias desastrosas para la organización
 - c) Grado de dependencia de la actualidad de los datos o RPO (Recovery Point Objective): determina el impacto que tiene sobre la actividad la pérdida de datos
 - d) Niveles mínimos de recuperación de servicio o ROL (Revised Operating Level): nivel mínimo de recuperación de una activad para estar recuperada a nivel de servicio óptimo
- 16) El análisis de riesgos determina:
- a) Amenazas, probabilidades e impactos
 - b) Amenazas, puntos críticos de la organización y probabilidades
 - c) Amenazas, puntos críticos de la organización e impactos
 - d) Amenazas e impactos
- 17) Que no se debe hacer con un riesgo:
- a) Eliminarlo
 - b) Asumirlo
 - c) Transferirlo a un tercero
 - d) Obviarlo
- 18) En base a la estrategia de continuidad, si tenemos un sistema A con una MTD de 24, que utiliza los sistemas B y C y los RTO de B y C son 48 y 12 respectivamente, cuál sería la mejor opción:
- a) Debemos asegurarnos que el MTD de B es 12
 - b) Debemos reducir el RPO de B a 12
 - c) Debemos reducir el RTO de C a 12
 - d) Debemos aumentar el RTO de C a 24
- 19) Qué documento se utiliza primero en una crisis:
- a) Plan de Crisis
 - b) Plan operativo de recuperación de entornos
 - c) Plan de pruebas
 - d) Plan de mantenimiento
- 20) El plan de mantenimiento se actualiza:
- a) Una vez al año

- b) Dos veces al año
- c) Cuando se produce un cambio en la organización
- d) Periódicamente

4.1 SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	a
2	c
3	d
4	a
5	a
6	d
7	a
8	d
9	d
10	d
11	a
12	a
13	d
14	b
15	d
16	a
17	d
18	c
19	a
20	c

5 BIBLIOGRAFÍA BÁSICA

1. AENOR, UNE-EN ISO 22301, Sistema de Gestión de la Continuidad de Negocio
2. Banco de España, Recomendaciones relativas a la continuidad del negocio, https://www.bde.es/f/webbde/COM/Supervision/politica/ficheros/es/Recomendaciones_relativas_a_la_continuidad_del_negocio.pdf
3. Instituto Nacional de Ciberseguridad (Incibe), Plan de Contingencia y Continuidad de Negocio, <https://www.incibe.es/protege-tu-empresa/blog/plan-contingencia-y-continuidad-negocio-herramientas-necesito>

6 BIBLIOGRAFÍA PARA AMPLIAR

1. ISO, UNE-EN ISO 22301, Security and resilience – Business continuity management systems – Requirements (ISO/DIS 22301:2019)
2. ISACA, Implementation Guideline ISO/IEC 27001:2013, https://www.isaca.de/sites/default/files/isaca_2017_implementation_guideline_isoiec27001_screen.pdf
3. Instituto Nacional de Ciberseguridad (Incibe), Blog de Continuidad de Negocio, <https://www.incibe.es/etiquetas-blog/continuidad-negocio>
4. WikiHOW, «How create a Business Continuity Plan», <http://www.wikihow.com/Create-a-Business-Continuity-Plan>